LAB 4 - VF-1D-A-696: Güvenli Uzak Erişim

Çıktı: Önerilen güvenli erişim mimarisi (Secure Architecture); Evidence Pack EP 02 ve EP 06 ile ilişkilidir.

Analizin kapsamı

Olası uzak bakım erişimi, LAB 2 bölgelemesi ve LAB 3'teki R02 senaryosu üzerinden değerlendirilmiştir. Erişim güvenliği ile SF1 güvenli erişim ve SF2 aşırı sıcaklık korumasının bağımsızlığı birlikte ele alınmıştır.

Görev A - Mevcut erişim senaryosu

VF-1D-A-696 için uzak bakım bağlantısı ve erişim yapılandırması doğrulanmamıştır. Karşılaştırmada R02'nin koşulları kullanılır: sürekli açık internet bağlantısı ve ele geçirilebilir bakım hesabı üzerinden koruma ayarlarına ulaşılabilmektedir.

Bu senaryoda saldırgan SF2 ayarlarını değiştirir, bağımsız koruma da etkilenirse tehlikeli ısınma yangına ve ağır yaralanmaya yol açabilir. Mevcut MFA, VPN ve kayıt durumu bilinmediğinden bunların bulunmadığı kabul edilmemiştir.

Görev A - Hedef erişim

Uzak bakım gerekiyorsa önerilen bağlantı yolu:

Yetkili bakım kullanıcısı → VPN + MFA → Uzak erişim / DMZ bölgesindeki jump server → İzinli bakım hedefi.

İlke	Fırın için önerilen karşılık
Ara nokta (jump server)	SCADA ve proses kontrolüne doğrudan internet erişimi açılmaz; bakım yalnız izin verilen hedef ve bağlantılara yönlendirilir.
Kişisel hesap	Bakım kullanıcısına kişisel ve görevle sınırlı yetki verilir; ortak hesap kullanılmaz.
MFA	VPN/uzak erişim girişinde parolaya ek ikinci kimlik doğrulama faktörü aranır.
Varsayılan kapalı	Bağlantı bakım onayıyla ve süreli açılır; iş bitiminde veya süre dolunca kapatılır.
Oturum kaydı	Kullanıcı, bağlantı zamanı, hedef ve yapılan işlemler kaydedilir; kayıtlar bakım hesabının değiştirmesine karşı korunur.

VPN trafiği şifreler; erişilebilecek hedefleri ve işlem yetkilerini tek başına belirlemez. LAB 2'deki bölge sınırları korunur. Uzak bakım hesabına emniyet yapılandırmasını doğrudan yazma veya SF1/SF2'yi devre dışı bırakma yetkisi verilmez. Emniyet değişikliği, ayrı yetki, yerel onay ve geçerleme sürecine bağlı kalır.

Görev B - Saldırgan içeri girerse emniyet etkilenir mi?

Evet, proses ve emniyet işlevleri yeterince ayrılmamışsa etkilenebilir. Saldırganın bakım veya SCADA erişiminden emniyet eşiklerine ve mantığına ulaşması, sıcaklık/basınç güvenli değilken erişim izni verilmesine (SF1) ya da aşırı sıcaklığın sınırlanamamasına (SF2) neden olabilir.

Erişim kontrolleri giriş olasılığını azaltır; hesabın ele geçirilmesi durumunda emniyetin korunması ayrıca değerlendirilmelidir. Ayrı bir denetleyici bulunması da ortak mühendislik yetkileri ve bağlantılar incelenmeden bağımsızlığı kanıtlamaz.

Görev B - Emniyet bağımsızlığı gereksinimi

Üretim kontrolü, SCADA veya uzak erişim altyapısının arızalanması ya da ele geçirilmesi, SF1 ve SF2'nin koruyucu görevini engellememelidir. Sıcaklık ve basınç koşulları güvenli olarak doğrulanmadan tehlikeli bölgeye erişim verilmemeli; tehlikeli aşırı sıcaklıkta ısıtma sınırlandırılmalıdır.

Bağlantı kesildiğinde de gerekli koruyucu soğutma ve izleme işlevleri sürdürülmelidir. Güvenli durum, yalnızca tüm enerjinin kesilmesi olarak tanımlanmaz; artık ısı ve basınç dikkate alınır. Güvenli eşikler ve tepki süreleri risk değerlendirmesiyle belirlenir; NADCA test değerleri emniyet eşiği değildir.

Bu gereksinim belirli bir Safety PLC veya ürün seçimi değildir.

Değerlendirmeyi destekleyecek kanıtlar

• Bağlantı envanteri ve izinli bakım hedefleri; doğrudan dış erişimin engellendiğini gösteren kurallar.

• Kişisel hesap, MFA, süreli onay ve korunan oturum kayıtları.

• Bakım hesabının emniyet parametresi yazamadığını ve bağlantı kaybının SF1/SF2'yi bozmadığını gösteren geçerleme kayıtları.

Bu kanıtlar henüz elde edilmediğinden R02 için artık risk puanı verilmemiştir.

Kaynaklar

• Genel LAB Föyleri: LAB 4, PDF s. 5; Bootcamp Sunumu: PDF s. 20; Kavramlar Sözlüğü: PDF s. 2.

• LAB 1 - SF1, SF2 ve güvenli durum.

• LAB 2 - Bölgeler ve bakım geçişleri.

• LAB 3 - Olası uzak bakım senaryosu.

• NIST SP 800-82 Rev. 3 - OT Security: uzak erişim ve emniyet için genel başvuru.

Sonuç

Uzak bakım gerekiyorsa erişim kişisel, kontrollü ve süreli olmalıdır. Temel emniyet hedefi, bakım erişimi ele geçirilse bile SF1/SF2'nin korunması ve fırının artık ısı ile basınç tehlikelerini gözeten güvenli durumda tutulmasıdır.